POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 NORMATIVA APLICABLE 5
4 MISIÓN Y OBJETIVOS 5
5 MARCO LEGAL 5
6 PROCESO DE IMPLANTACIÓN DEL SISTEMA DE SEGURIDAD 5
7 ORGANIZACIÓN DE SEGURIDAD 7
8 PROCEDIMIENTO DE DESIGNACIÓN 7
9 RESOLUCIÓN DE CONFLICTOS 7
10 SEGREGACIÓN DE FUNCIONES 8
11 CATEGORIZACIÓN DE SISTEMA 8
12 CATEGORIZACIÓN DE LA INFORMACIÓN 8
13 AUTORIZACIÓN Y CONTROL DE ACCESOS LÓGICOS 9
14 AUTORIZACIÓN Y CONTROL DE ACCESOS FÍSICOS 9
15 MÍNIMO PRIVILEGIO 10
16 INTEGRIDAD Y ACTUALIZACIÓN DE LOS SISTEMAS 10
17 PROTECCIÓN DE LA INFORMACIÓN ALMACENADA Y EN TRÁNSITO 11
18 REGISTRO DE LA ACTIVIDAD Y CÓDIGO DAÑINO 11
19 GESTIÓN DE INCIDENTES DE SEGURIDAD 12
20 CONTINUIDAD DE LA ACTIVIDAD 12
21 MEJORA CONTINUA DEL PROCESO DE SEGURIDAD 12
22 GESTIÓN DEL PERSONAL Y PROFESIONALIDAD 13
23 CONCIENCIACIÓN Y FORMACIÓN EN SEGURIDAD DE LA INFORMACIÓN 14
24 ADQUISICIÓN DE PRODUCTOS DE SEGURIDAD Y NUEVOS COMPONENTES 14
25 GESTIÓN Y ANÁLISIS DE RIESGOS 15
26 OBLIGACIONES Y COMPROMISOS DE LOS USUARIOS 16
27 TERCERAS PARTES 17
28 REGISTROS Y ARCHIVOS 17
29 REFERENCIAS 17

1 OBJETIVO

SPIKA TECH depende de los sistemas TIC (Tecnologías de Información y Comunicaciones) para alcanzar sus objetivos de negocio. En este contexto, la compañía es consciente de que estos sistemas deben ser administrados con diligencia, tomando las medidas adecuadas para protegerlos frente a daños accidentales o deliberados que puedan afectar a la disponibilidad, integridad o confidencialidad de la información tratada o los servicios prestados. En este sentido, SPIKA TECH ha decido implantar un Sistema de Gestión de la Seguridad de la Información basado en el Sistema de Gestión de la Seguridad de la Información ISO 27001/27002.

La presente política materializa el compromiso de SPIKA TECH en materia de seguridad de la información y lo que en ella se expone, es de obligado cumplimiento para toda la organización y se orienta al cumplimiento de los siguientes requisitos mínimos:

a) Organización e implantación del proceso de seguridad.
b) Análisis y gestión de los riesgos.
c) Gestión de personal.
d) Profesionalidad.
e) Autorización y control de los accesos.
f) Protección de las instalaciones.
g) Adquisición de productos de seguridad y contratación de servicios de seguridad.
h) Mínimo privilegio.
i) Integridad y actualización del sistema.
j) Protección de la información almacenada y en tránsito.
k) Prevención ante otros sistemas de información interconectados.
l) Registro de la actividad y detección de código dañino.
m) Incidentes de seguridad.
n) Continuidad de la actividad.
o) Mejora continua del proceso de seguridad.

2 ALCANCE

Esta Política de seguridad TIC es de aplicación, con carácter obligatorio, sobre todos los sistemas TIC responsabilidad de SPIKA TECH, servicios y procesos de negocio, activos de información y sus dependencias, personal interno o externo que tenga acceso información o sistemas del SPIKA TECH (con independencia de que exista o no una relación de carácter

laboral) y, cualquier otra entidad involucrada con SPIKA TECH en la utilización de su información y sus sistemas.

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE.xlsx.**, que se actualizara de forma periódica y en base a los cambios normativos que puedan afectar. Las Políticas, Normas y Procedimientos dentro del alcance del SGSI, se actualizarán, si procede, en su versión más reciente.

4 MISIÓN Y OBJETIVOS

La misión de SPIKA TECH es ofrecer una ventaja competitiva apostando por la investigación y la innovación en diferentes sectores. Para ello fusiona procesos de diseño y programación, utilizando las últimas técnicas. Buscando la calidad en su desarrollo. A la consecución de estos fines contribuyen los cinco valores desarrollados en el esenciales, que imprimen el carácter SPIKA TECH:

- Confiabilidad.
- Compromiso.
- Aprendizaje continuo.
- Excelencia.
- Innovación

5 MARCO LEGAL

El marco legal se revisará cuando sea necesario por el director de ciberseguridad, o al menos, una vez al año y en caso necesario, se adaptarán los documentos de Sistema de Gestión de Seguridad de la Información conforme a los cambios legislativos aplicables por los departamentos, autoridades o comisiones que correspondan. La legislación de referencia se mantendrá actualizada en un documento denominado **RGS_1 NORMATIVA APLICABLE.**

6 PROCESO DE IMPLANTACIÓN DEL SISTEMA DE SEGURIDAD

El proceso de implantación de la política se establece a tres niveles mediante, políticas, normas y procedimientos operativos de seguridad que afronten aspectos específicos según el marco legal y regulatorio vigente:

a) Las Políticas son elaboradas por el responsable del SGSI, revisadas por la dirección y aprobadas por el jefe de seguridad (o suplente). Las políticas son documentos donde se reflejan un conjunto de directrices y reglas que deben ser conocidas por todos los usuarios de la organización. Estas políticas definen cómo los empleados, usuarios y sistemas deben manejar y proteger los datos sensibles.

b) Las Normas son elaboradas por el responsable del SGSI, revisadas por la dirección y aprobadas por el jefe de seguridad (o suplente). Las Normas son documentos que sirven para indicar cómo se debe actuar de manera adecuada, especialmente en el caso de que una cierta circunstancia no esté recogida en un procedimiento específico. Son el conjunto de regulaciones que desarrollan la política de seguridad y tratan de su aplicación.

Cada norma deberá:

1. Centrarse en los objetivos que se desean alcanzar, antes que en la forma de lograrlo. Las normas ayudan a tomar la decisión correcta en caso de duda.

2. Describir lo que se considera uso correcto, así como lo que se considera uso incorrecto.

3. Indicar la forma de localizar los procedimientos de seguridad y privacidad que se han desarrollado en la materia tratada.

4. Ser concisa, motivada y descriptiva, y definir puntos de contacto para su interpretación correcta.

5. Explicar cómo actuar ante situaciones anómalas y no previstas.

6. Describir la responsabilidad del personal con respecto al cumplimiento o violación de la norma: derechos, deberes y medidas disciplinarias de acuerdo con la legislación vigente.

Existe una **Norma general de utilización de los recursos y sistemas de información**. Esta normativa de seguridad estará a disposición de todos los miembros de la organización que necesiten conocerla, en particular para aquellos que utilicen, operen o administren los sistemas de información y comunicaciones.

c) Los Procedimientos Operativos de Seguridad son elaboradas por el responsable del SGSI, revisadas por la dirección y aprobadas por el jefe de seguridad (o suplente). Los Procedimientos Operativos de Seguridad son documentos detallados donde se reflejan instrucciones detalladas y específicas que definen como debe una tarea o proceso de forma concreta.

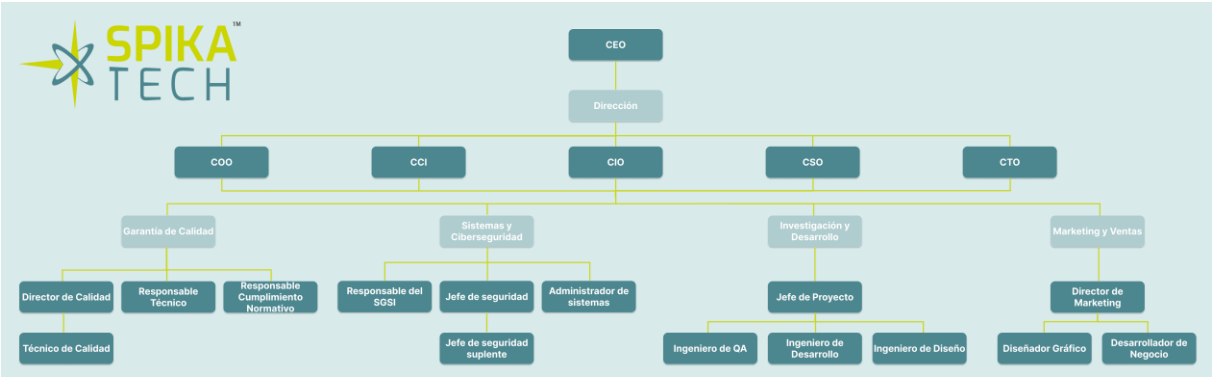
7 ORGANIZACIÓN DE SEGURIDAD

Toda la organización tiene responsabilidades en materia de Seguridad de la Información, con independencia de las figuras y responsables establecidos. La organización y las responsabilidades específicas de seguridad se articulan en base a lo detallado en el **Procedimiento de roles y segregación de funciones.**

8 PROCEDIMIENTO DE DESIGNACIÓN

Todos los roles de la empresa son asignados por la dirección de Spika Tech, ya sean roles relacionados con el SGSI o no.

Actualmente la estructura de la empresa es la siguiente:



9 RESOLUCIÓN DE CONFLICTOS

En caso de tener que solucionar conflictos en lo que se establece en la presente Política, la decisión será tomada por el superior o superiores jerárquicos (nivel C), que podrán solicitar asesoramiento previo del responsable del SGSI.

10 SEGREGACIÓN DE FUNCIONES

En SPIKA TECH se seguirá el principio de Segregación de funciones, es decir, el responsable de la supervisión de la ciberseguridad debe ser distinto del responsable de la operación del sistema y nadie puede autorizarse a sí mismo, por lo que los roles, perfiles, permisos y privilegios, deben estar bien definidos y delimitados para cada puesto de trabajo.

11 CATEGORIZACIÓN DE SISTEMA

Todos los sistemas de SPIKA TECH tendrán una categorización (sistemas que manejan información no clasificada), adecuada a la información y servicios que proporcionan. La determinación de la categoría de un sistema se basa en la valoración del impacto que tendría sobre la organización un incidente que afectara a la seguridad de la información o de los sistemas, con repercusión en la capacidad organizativa para:

a) Alcanzar sus objetivos.

b) Proteger los activos a su cargo.

c) Cumplir sus obligaciones diarias de servicio.

d) Respetar la legalidad vigente.

e) Respetar los derechos de las personas. La categorización de los sistemas de información será responsabilidad del Responsable del SGSI junto con los responsables de la Información en base a las dimensiones de confidencialidad, integridad y disponibilidad.

12 CATEGORIZACIÓN DE LA INFORMACIÓN

La información generada en SPIKA TECH, se categorizará por la persona que la genera y siempre se realizará en base a las siguientes categorías y criterios establecidos por el responsable del SGSI junto con los Responsables de la información correspondientes. Toda información en soporte papel y en soportes informáticos se etiquetarán adecuadamente en base a su categorización para facilitar su uso, manipulación y protección. Existirá para ello un Procedimiento de calificación y etiquetado de la información.

13 AUTORIZACIÓN Y CONTROL DE ACCESOS LÓGICOS

El acceso al sistema de información deberá ser controlado y limitado a los usuarios, procesos, dispositivos y otros sistemas de información, debidamente autorizados, restringiendo el acceso a las funciones permitidas. Para ello, todo el personal que acceda a las instalaciones de SpikaTech deberá estar debidamente autorizado e identificado. Los sistemas de información y su infraestructura de comunicaciones asociada deberán permanecer en áreas controladas y disponer de los mecanismos de acceso adecuados y proporcionales en función del análisis de riesgos.

Para el acceso a los dispositivos informáticos como portátiles, se necesita la contraseña de acceso. Todos los dispositivos informáticos de la empresa cuentan con una contraseña de protección que cumple la política de contraseñas.

En el caso de servicios como la nube, base de datos o sistemas de backup, solo tienen acceso las personas que tienen permisos para manejarlas.

En el caso de la información física, toda está almacenada en las oficinas de Spika Tech, y la que es de nivel interno restringido es guardada bajo llave, la cual solo tienen algunos miembros de Spika Tech.

14 AUTORIZACIÓN Y CONTROL DE ACCESOS FÍSICOS

Las salas deben estar cerradas y disponer de un control de llaves. Las zonas de trabajo se clasificarán adecuadamente en función de la información a manejar en las mismas y contarán con las medidas de protección adecuadas a la información a manejar.

Para el acceso físico a la oficina de Sika Tech es necesario estar en posesión de la llave que abre la puerta, la cual solo está abierta cuando algún empleado se encuentra en el interior, en caso contrario, la oficina permanecerá cerrada con llave. Dicha llave la tienen solamente algunos miembros de la empresa. En el caso del servicio de limpieza, queda un registro de quien y cuando ha entrado.

Spika Tech no cuenta con servidores físicos, solamente cuenta con ordenadores y sistemas de backup, los cuales están protegidos como se ha explicado en el punto 13.

15 MÍNIMO PRIVILEGIO

Los usuarios y administradores contarán con los mínimos privilegios que sean necesarios para hacer su trabajo. En caso de que un usuario necesite un mayor privilegio, de forma temporal o permanente, lo solicitará mediante los canales establecidos para su estudio o autorización si procede. En cuanto dejen ser necesarios los privilegios serán retirados a la mayor brevedad. Hay que tener en cuenta, que un mayor nivel de privilegio también requiere una mayor responsabilidad y conocimientos por parte de la persona que lo solicita.

Los sistemas de información deben diseñarse y configurarse otorgando los mínimos privilegios necesarios para su correcto desempeño, atendiendo especialmente lo siguiente:

a) El sistema proporcionará la funcionalidad imprescindible para que la organización alcance sus objetivos competenciales o contractuales.

b) Las funciones de operación, administración y registro de actividad serán las mínimas necesarias, y se asegurará que sólo son desarrolladas por las personas autorizadas, desde emplazamientos o equipos asimismo autorizados; pudiendo exigirse, en su caso, restricciones de horario y puntos de acceso facultados.

c) Se eliminarán o desactivarán, mediante el control de la configuración, las funciones que sean innecesarias o inadecuadas al fin que se persigue. El uso ordinario del sistema ha de ser sencillo y seguro, de forma que una utilización insegura requiera de un acto consciente por parte del usuario.

d) Se aplicarán guías de configuración de seguridad para las diferentes tecnologías, adaptadas a la categorización del sistema, al efecto de eliminar o desactivar las funciones que sean innecesarias o inadecuadas.

16 INTEGRIDAD Y ACTUALIZACIÓN DE LOS SISTEMAS

Todo elemento físico o lógico requerirá autorización formal previa a su instalación en el sistema, lo que se materializará en una petición. Se deberá conocer en todo momento el estado de seguridad de los sistemas, en relación con las especificaciones de los fabricantes, a las vulnerabilidades y a las actualizaciones que les afecten, reaccionando con diligencia para gestionar el riesgo a la vista del estado de seguridad de este. La evaluación y monitorización permanentes permitirán adecuar el estado de seguridad de los sistemas

atendiendo a las deficiencias de configuración, las vulnerabilidades identificadas y las actualizaciones que les afecten, así como la detección temprana de cualquier incidente que tenga lugar sobre los mismos. Todo el software y el hardware deberá estar actualizado con los últimos parches de seguridad, debidamente licenciado y con soporte del fabricante. Se mantendrá un adecuado control y gestión de la obsolescencia, para lo que las distintas áreas de SPIKA TECH establecerán en sus presupuestos las necesidades de mantenimiento de licencias de software y de mantenimiento y sustitución de hardware. En el caso de tener que mantenerse obsolescencia por requisitos del servicio, cliente o del producto, se tomarán las medidas compensatorias que se consideren más adecuadas. En todo caso de valorará el coste y los riesgos de mantener la obsolescencia en los sistemas y siempre que sea posible, se llevarán a cabo planes de gestión o de eliminación de esta.

17 PROTECCIÓN DE LA INFORMACIÓN ALMACENADA Y EN TRÁNSITO

En la estructura y organización de la seguridad del sistema, se prestará especial atención a la información almacenada o en tránsito a través de entornos inseguros. Tendrán la consideración de entornos inseguros los equipos portátiles o móviles, los asistentes personales (PDA), los dispositivos periféricos, los soportes de información y comunicaciones sobre redes abiertas o con cifrado débil, que deberán analizarse especialmente para lograr una adecuada protección de la información. Toda información en soporte no electrónico, que haya sido causa o consecuencia directa de la información electrónica a la que se refiere la norma ISO 27001, deberá estar protegida con el mismo grado de seguridad que ésta. Para ello se aplicarán las medidas que correspondan a la naturaleza del soporte en que se encuentren, de conformidad con las normas de aplicación a la seguridad de éstos. Se establecerá un procedimiento de sanitización y destrucción de soportes de información conforme a la normativa aplicable y guías en función de los distintos tipos de información.

También se elaborará un procedimiento de categorización de la información, para permitir el tratamiento adecuado de la misma por parte de todos los miembros de la organización.

18 REGISTRO DE LA ACTIVIDAD Y CÓDIGO DAÑINO

Con la finalidad exclusiva de lograr el cumplimiento de la ISO 27001 y sobre la base de un interés legítimo y proporcionado, con plenas garantías del derecho al honor, a la intimidad personal y familiar y a la propia imagen de los afectados, y de acuerdo con la normativa sobre protección de datos personales, de función pública o laboral, y demás disposiciones que

resulten de aplicación, se registrarán las actividades de los usuarios, reteniendo la información necesaria para analizar, investigar y documentar actividades indebidas o no autorizadas, permitiendo identificar en cada momento a la persona que actúa. Todos los sistemas de SPIKA TECH, sean físicos o virtuales, estarán protegidos contra el código dañino mediante las aplicaciones y sistemas de seguridad que sean necesarios.

19 GESTIÓN DE INCIDENTES DE SEGURIDAD

Se establecerá un sistema de detección, monitorización y reacción frente a código dañino 24/7. Se dispondrá de **procedimientos de gestión de incidentes de seguridad**. Estos procedimientos cubrirán los mecanismos de detección, los criterios de clasificación, los procedimientos de análisis y resolución, así como los cauces de comunicación a las partes interesadas y el registro de las actuaciones. Este registro se empleará para la mejora continua de la seguridad del sistema. Dicha gestión de incidentes será acorde con la documentación aplicable y la Guía Nacional de Notificación y Gestión de Ciberincidentes.

20 CONTINUIDAD DE LA ACTIVIDAD

Los sistemas dispondrán de copias de seguridad y establecerán los mecanismos necesarios para garantizar la continuidad de las operaciones, en caso de pérdida de los medios habituales de trabajo. Se elaborará un procedimiento de gestión de copias de seguridad y un plan de continuidad de negocio.

21 MEJORA CONTINUA DEL PROCESO DE SEGURIDAD

En este sentido, SPIKA TECH deberá reevaluar y actualizar las medidas de seguridad periódicamente, adecuando su eficacia a la evolución de los riesgos y sistemas de protección, bien por la aparición o incremento de los riesgos o bien en cumplimiento de la normativa vigente sobre un modelo de mejora continua. Para ello, se aplicarán los criterios y métodos reconocidos en la práctica nacional e internacional relativos a gestión de las tecnologías de la información. Este proceso se basará en el conocimiento de la amenaza, de las debilidades observadas y en el análisis y lecciones aprendidas obtenidas de eventos e incidentes de seguridad.

22 GESTIÓN DEL PERSONAL Y PROFESIONALIDAD

Todo el personal relacionado con la información y los sistemas deberá ser formado e informado de sus deberes y obligaciones en materia de seguridad. Sus actuaciones deben ser supervisadas para verificar que se siguen los procedimientos establecidos.

El personal relacionado con la información y los sistemas ejercitará y aplicará los principios de seguridad en el desempeño de su cometido.

Se llevará a cabo una adecuada caracterización del puesto de trabajo, teniendo en cuenta las obligaciones, los perfiles y la adecuada verificación de antecedentes en la contratación.

El significado y alcance del uso seguro del sistema se concretará y plasmará en unas normas de seguridad.

Para corregir, o exigir responsabilidades en su caso, cada usuario que acceda a la información del sistema debe estar identificado de forma única, de modo que se sepa, en todo momento, quién recibe derechos de acceso, de qué tipo son éstos, y quién ha realizado determinada actividad.

Se dispondrá de un procedimiento sancionador orientado al incumplimiento de las medidas de seguridad, que será conforme a la legislación aplicable, convenio colectivo en vigor y Estatuto de los Trabajadores, que deberá ser conocido por todo el personal de la empresa.

También se dispondrá de una normativa de puesto de trabajo despejado, así de los medios necesarios para que sea llevada a cabo.

La seguridad de los sistemas estará atendida, revisada y auditada por personal cualificado, dedicado e instruido en todas las fases de su ciclo de vida: planificación, diseño, adquisición, construcción, despliegue, explotación, mantenimiento, gestión de incidencias y desmantelamiento.

El personal recibirá la formación específica necesaria para garantizar la seguridad de las tecnologías de la información aplicables a los sistemas y servicios de SPIKA TECH.

23 CONCIENCIACIÓN Y FORMACIÓN EN SEGURIDAD DE LA INFORMACIÓN

Todo el personal de SPIKA TECH, recibirá de forma continua píldoras, infografías y demás materiales referentes a seguridad de la información. Asimismo, se pondrá en conocimiento de todos los usuarios los diferentes materiales que organismos oficiales como el CCN-CERT tiene a disposición de los usuarios.

Se entiende como:

a) Concienciación, la sensibilización al problema de la ciberseguridad. Está orientada a la organización.
b) Formación, la adquisición de habilidades básicas de ciberseguridad para el desarrollo de sus competencias profesionales. Está orientada al puesto de trabajo y a los cometidos de la persona que lo ocupa.

24 ADQUISICIÓN DE PRODUCTOS DE SEGURIDAD Y NUEVOS COMPONENTES

En la adquisición de productos de seguridad de las tecnologías de la información y comunicaciones que vayan a ser empleados por SPIKA TECH se utilizarán, de forma proporcionada a la categoría del sistema y nivel de seguridad determinados, aquellos que tengan certificada la funcionalidad de seguridad relacionada con el objeto de su adquisición, salvo en aquellos casos en que las exigencias de proporcionalidad en cuanto a los riesgos asumidos no lo justifiquen a juicio del Director de ciberseguridad.

Se establecerá un proceso formal para planificar la adquisición de nuevos componentes del sistema sujetos al SGSI.

Proceso que:

a) Atenderá a las conclusiones del análisis de riesgos.

b) Será acorde a la arquitectura de seguridad escogida.

c) Contemplará las necesidades técnicas, de formación y de financiación de forma conjunta. La certificación indicada en el apartado anterior deberá estar de acuerdo con las normas y estándares de mayor reconocimiento internacional, en el ámbito de la seguridad funcional.

Para la contratación de servicios de ciberseguridad se estará a lo dispuesto en los apartados anteriores y lo relativo a la profesionalidad del personal. Se elaborará una norma de Gestión de Riesgos de Proveedores y un Anexo de Seguridad de la Información para los contratos. Los contratos se valorarán también por el nivel de seguridad del proveedor y se podrán establecer Sistemas de Gestión de la Seguridad de la Información y de mejora continua de la ciberseguridad con los proveedores críticos para la continuidad del negocio o que se conecten a la infraestructura de SPIKA TECH.

25 GESTIÓN Y ANÁLISIS DE RIESGOS

Cada área de SPIKA TECH que desarrolle e implante sistemas para el tratamiento de la información y las comunicaciones realizará su propio análisis y gestión de riesgos. Todos los sistemas sujetos a esta Política de Seguridad de la Información deberán disponer de su correspondiente Análisis de Riesgos, evaluando las amenazas y los riesgos a los que están expuestos, como base para la adecuada selección de las salvaguardas necesarias, optimizando así, el coste beneficio.

Este análisis se revisará regularmente:

- Al menos una vez al año.
- Cuando cambie la información manejada.
- Cuando cambie la arquitectura de la red o los servicios prestados.
- Cuando cambien de forma sustancial los procesos internos.
- Cuando se actualicen las herramientas de análisis de riesgo.
- Cuando ocurra un incidente grave de seguridad.
- Cuando se reporten vulnerabilidades graves.

La gestión de riesgos en SPIKA TECH se realizará mediante la metodología Magerit y todas las decisiones en relación con configuración, tecnologías y salvaguardas de seguridad, se basarán en el resultado del análisis de riesgo (no formal, semiformal o formal, según corresponda). Las medidas adoptadas para mitigar o suprimir los riesgos, deberán estar debidamente justificadas y, en todo caso, existirá una proporcionalidad entre ellas y los riesgos. Para la armonización de los análisis de riesgos, el Responsable del SGSI establecerá una valoración de referencia para los diferentes tipos de información manejada y los diferentes servicios prestados.

En la implementación de salvaguardas se considerará la aplicación de tecnología, la implantación de Procedimientos Operativos de Seguridad, la aceptación de riesgos de baja ocurrencia y bajo impacto o la externalización de los riesgos, según proceda y los recursos disponibles. Por lo general ante los riesgos muy altos o altos siempre se debe aplicar tecnología para evitar el impacto del fallo humano, en los riesgos medios y bajos se puede considerar la aplicación de Procedimientos Operativos de Seguridad o la externalización de éstos. En ningún caso, la externalización se podrá considerar como sustituto de otras salvaguardas y siempre como un complemento a éstas.

26 OBLIGACIONES Y COMPROMISOS DE LOS USUARIOS

Todos los miembros de SPIKA TECH tienen la obligación de conocer y cumplir esta Política de Seguridad de la Información, Normativa y Procedimientos de Seguridad que le afecten, siendo responsabilidad del Responsable del SGSI el disponer de los medios necesarios para que la información llegue a los afectados y de sus responsables, y que el personal a su cargo los conozca y apliquen adecuadamente.

Todos los miembros de SPIKA TECH tienen la obligación de atender de forma prioritaria y diligente las alertas de seguridad y las instrucciones que reciban de los responsables de seguridad de la organización.

Todos los miembros de SPIKA TECH recibirán concienciación y/o formación de forma anual. Las personas con responsabilidad en el uso, operación o administración de sistemas TIC recibirán formación para el manejo seguro de los sistemas en la medida en que la necesiten para realizar su trabajo. La formación será obligatoria antes de asumir la responsabilidad de dicho puesto, tanto si es su primera asignación o si se trata de un cambio de puesto de trabajo o de responsabilidades en el mismo. Todos los correos de alertas de ciberseguridad son prioritarios y sus indicaciones de obligado cumplimiento a la mayor brevedad por parte de todo el personal de la empresa, por lo que los responsables con personal a su cargo deben velar por el conocimiento y cumplimiento inmediato de las medidas y recomendaciones contempladas en dichos mensajes, por parte de todo el personal que dependa de ellos. Los usuarios asumirán las responsabilidades del incumplimiento ante cualquier medida urgente que tenga impacto en la ciberseguridad, en el caso de materializarse un incidente por el incumplimiento de esta.

27 TERCERAS PARTES

Cuando SPIKA TECH preste servicios a otros organismos o maneje información de otros organismos, se les hará partícipes de esta Política de Seguridad de la Información.

La presente política de seguridad de la información estará disponible para su consulta en la página web de la organización y será puesta a disposición de las terceras partes que accedan a información o sistemas de SPIKA TECH.

Con el objetivo de salvaguardar la información decida a terceras partes, estas deberán cumplir con una serie de medidas mínimas de seguridad de la información. Estas medidas estarán dispuestas en un documento que será entregado por SPIKA TECH al inicio de la relación con la tercera parte.

28 REGISTROS Y ARCHIVOS

	Nombre del registro	Versión y Modificaciones
REGISTRO	**RGS_1 NORMATIVA APLICABLE**	Creación 05/10/2024

29 REFERENCIAS

- Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016.
- Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales.
- ISO 27001:2022:
  - 5.1 Políticas para la seguridad de la información.
  - 5.36 Cumplimiento de las políticas y normas de seguridad de la información.